UNIVERSIDAD DE OCCIDENTE / INGENIERÍA EN SISTEMAS E INFORMÁTICA

OPERACIÓN TRAZABILIDAD

Auditoría integral de sistemas ante un ciberataque

Un caso integral de riesgos, evidencias, ataque malicioso, hallazgos y plan de acción verificable.

15 PUNTOS	ALTO	8.º SEMESTRE
PONDERACIÓN	NIVEL	CURSO

Curso: Auditoría de Sistemas

Docente: Ing. Herman Ávila

Fecha: Octubre de 2026

Institución: Universidad de Occidente, Guatemala

REGLA FUNDAMENTAL

Sin evidencia suficiente y pertinente no puede sostenerse un hallazgo. Las sospechas deben investigarse, no presentarse como hechos confirmados.

01 / PROPÓSITO DEL PROYECTO

La Universidad de Occidente designa a cada equipo como una firma de auditoría independiente para evaluar el ambiente tecnológico de RedNova Guatemala, S. A. El encargo cubre la identificación de riesgos previos a un incidente, la auditoría de los controles involucrados en un ataque malicioso y el seguimiento de medidas para contener, recuperar y prevenir nuevas afectaciones.

Resultados de aprendizaje: planificar bajo un enfoque basado en riesgos; evaluar ITGC, controles de aplicaciones, bases de datos, desarrollo, nube, terceros e IA; documentar papeles de trabajo; formular hallazgos; comunicar decisiones y verificar resultados.

FASE 1 · PREVENCIÓN	FASE 2 · INCIDENTE	FASE 3 · MEJORA
Auditar riesgos, activos y controles antes del ataque.	Reconstruir hechos, hipótesis, impacto, evidencias y respuesta.	Proponer contención, recuperación y controles duraderos con métricas.

MODALIDAD

Trabajo en equipos (sugerido: 3 a 4 estudiantes). Análisis sobre datos ficticios o laboratorios autorizados. No se permiten ataques, explotación o pruebas intrusivas contra infraestructuras reales.

02 / CONTEXTO EMPRESARIAL

RedNova Guatemala, S. A. es un operador ficticio de internet residencial, televisión digital y soluciones tecnológicas que opera en varios departamentos de Guatemala. En los últimos dos años aceleró su transformación digital y subcontrató servicios de nube, integraciones y soporte.

Dato de negocio	Magnitud	Dato de negocio	Magnitud
Clientes registrados	85,000	Colaboradores	420
Vendedores y distribuidores	120	Sucursales y centros de atención	18

Inventario inicial de tecnología

Componente	Uso	Punto de auditoría
CRM comercial	Clientes, contratos, órdenes y ventas	Confidencialidad, autorizaciones, modificaciones.
SQL Server	Almacén de clientes, operaciones y facturación	Permisos, cifrado, registros, respaldo e integridad.
ERP	Facturación, cobros, inventarios y finanzas	Conciliación y segregación de funciones.
Aplicación móvil	Registro de ventas e instalaciones	Autenticación, permisos y datos personales.
Identidad / VPN	Acceso remoto y cuentas internas o externas	MFA, privilegios, bajas, sesiones.
Nube / respaldos	Servidores y servicios híbridos	Responsabilidad compartida y recuperación.
Monitoreo / SIEM	Alertas y retención de logs	Integridad, cobertura y atención de alertas.
Chatbot con IA / API	Atención, clasificación de solicitudes e integraciones	Gobierno de IA, proveedores y exposición de datos.

03 / ESCENARIO PREVIO: DOCE ALERTAS DE RIESGO

Treinta días antes del incidente, Auditoría Interna recibió avisos que todavía no han sido contrastados. **Ninguna alerta constituye por sí sola un hallazgo confirmado.**

01. Empleados desvinculados podrían conservar usuarios activos.

02. Existen cuentas administrativas compartidas entre personal interno y externo.

03. La autenticación multifactor (MFA) no cubre todos los accesos privilegiados.

04. Se desplegó una actualización comercial sin documentación completa de pruebas y aprobación.

05. Un proveedor de nube utiliza subcontratistas no incluidos en la evaluación TPRM.

06. La información personal de clientes no tiene clasificación formal documentada.

07. Los respaldos son automáticos, pero no se prueban restauraciones periódicas.

08. Ciertos administradores podrían alterar o eliminar registros de auditoría.

09. La aplicación móvil permitiría consultar información ajena al perfil autorizado.

10. El chatbot con IA procesa datos de clientes sin evaluación completa de privacidad, exactitud y supervisión.

11. El análisis de impacto al negocio (BIA) y los planes de continuidad están desactualizados.

12. El Comité de Riesgos carece de indicadores consolidados de ciberseguridad y terceros.

DECISIÓN DE AUDITORÍA

Separar riesgo, vulnerabilidad, falla de control, indicio y hallazgo. Para cada alerta definir qué evidencia se solicitará, cómo se evaluará y qué estándar o criterio será utilizado.

04 / EL INCIDENTE MALICIOSO

El **miércoles 14 de octubre de 2026**, la empresa pierde el acceso a su CRM. Aparecen archivos presuntamente cifrados y una nota exigiendo un pago para recuperarlos. Se sospecha ransomware y extracción de información. **La presencia de un mensaje de extorsión no confirma por sí misma exfiltración, autoría ni alcance.**

Cronología preliminar (horario de Guatemala, UTC−6)

Fecha/hora	Registro preliminar
12 oct. 16:15	Proveedor solicita renovación de acceso privilegiado a una API; autorización pendiente.
14 oct. 02:17	Inicio de sesión remoto de cuenta ext_ops_04 sin MFA.
02:26	Servicio de identidad registra elevación de privilegios.
02:31	SQL Server registra lectura de 31,840 registros de clientes.
02:35	Monitoreo identifica transferencia de ~1.6 GB hacia destino externo no clasificado.
02:42	CRM registra cambios en 216 órdenes comerciales.
03:02	Se ejecuta despliegue de versión nueva del servicio de integración.
03:18	Sistema de seguridad emite alerta crítica sobre actividad sospechosa.
03:42	CRM deja de estar disponible; archivos aparentemente cifrados.
04:05	TI solicita activar recuperación ante desastres.
08:57	CRM retorna en modo solo consulta.
09:37	Se restablecen operaciones de escritura.
11:15	Finanzas solicita conciliación de órdenes y facturación.

Impacto operativo reportado

- Interrupción comercial, problemas de facturación e indisponibilidad parcial.
- Posible exposición de información personal y alteración de órdenes.
- Riesgo de pérdida de transacciones y diferencias entre producción y respaldos.
- Conflicto contractual con terceros, riesgo financiero, operacional y reputacional.

05 / CONTRADICCIONES QUE DEBE RESOLVER EL AUDITOR

Fuente	Declaración inicial
Gerencia de Tecnología	“La responsabilidad del incidente es exclusivamente del proveedor”.
Proveedor cloud	“La falla se originó en una configuración a cargo del cliente; nuestro SLA no se incumplió”.
Desarrollo	“El despliegue estaba autorizado verbalmente”, sin aprobación formal presentada.
Administrador de BD	“Los datos están intactos”, aunque la conciliación aún no ha concluido.
Seguridad Informática	Califica 1.6 GB de tráfico como fuga, pero aún no identifica los datos transferidos.
Comité de Auditoría	El informe SOC 2 presentado por el tercero no cubre todos los servicios contratados.
Continuidad	La restauración documentada más reciente ocurrió varios meses antes del incidente.

Regla: *No convertir una declaración en evidencia concluyente. Registrar hipótesis alternativas y limitaciones. La secuencia temporal por sí sola no demuestra causalidad.*

06 / EXPEDIENTE DE EVIDENCIA INICIAL

ID	Tipo	Señal observada
E-01	Usuarios y privilegios	Cuentas activas sin recertificación reciente.
E-02	Acceso VPN	Sesión externa sin MFA.
E-03	Bitácora SQL Server	Lectura masiva de 31,840 filas.
E-04	Tráfico cloud	Transferencia de ~1.6 GB sin clasificación del contenido.
E-05	Cambios del CRM	216 órdenes modificadas.
E-06	Ticket de cambios	Aprobación final no documentada.
E-07	Alertas de seguridad	Alerta crítica sin cierre documentado.
E-08	Respaldos	Respaldos programados, restauración no probada recientemente.
E-09	Contrato del tercero	SLA 99.9 % con exclusiones sujetas a interpretación.
E-10	Chatbot con IA	Clasificación de una sesión anómala con valor de riesgo 0.08.

ADVERTENCIA FORENSE

Este expediente es un resumen inicial, no una extracción autenticada de sistemas. Corresponde al estudiante solicitar o generar en laboratorio registros sintéticos verificables, anotar supuestos y reconocer qué preguntas no pueden cerrarse con las pruebas disponibles.

07 / MISIONES OBLIGATORIAS DE AUDITORÍA

MISIÓN A · Planeación ITAF

Definir carta de encargo, objetivos, alcance, exclusiones, período, independencia, criterios, sistema de papeles de trabajo, cronograma y recursos. Justificar materialidad y priorización.

MISIÓN B · Riesgos y gobierno

Construir matriz con **mínimo 12 riesgos** y cinco críticos o prioritarios, mapa de proceso, inventario de activos, matriz RACI, controles preventivos/detectivos/correctivos y evaluación inherente/residual.

MISIÓN C · Técnica y forense

Auditar accesos, cuentas privilegiadas, segregación de funciones, operaciones, SQL Server, aplicaciones, API, seguridad móvil, ciclo de desarrollo, cambios, monitoreo, respaldos, BIA y continuidad. Presentar seis consultas SQL **de solo lectura**, cronología investigada y causa raíz.

MISIÓN D · Terceros, privacidad e IA

Realizar evaluación TPRM del proveedor y sus subcontratistas, responsabilidad compartida cloud, alcance SOC 2, cláusulas de SLA, retención de datos, implicaciones jurídicas verificadas y pruebas controladas del chatbot de IA.

MISIÓN E · Hallazgos y tratamiento

Redactar **cinco hallazgos completos como mínimo**, priorizarlos, identificar responsables, plantear la contención y recuperación, establecer plan de mejora a 90 días y prueba de cierre de cada control.

Consultas SQL y analítica

El equipo deberá construir una base de datos sintética con tablas como Usuarios, Sesiones, Permisos, Ordenes, HistorialCambios y Backups. Adjuntará diseño lógico, datos de prueba, **mínimo seis consultas SELECT** para detectar anomalías, capturas o exportación de resultados, interpretación y limitaciones. Queda prohibido utilizar datos reales de clientes.

Matriz de riesgo requerida

Adoptar, documentar y aplicar una escala de 1 a 5 para probabilidad y para impacto. Puntaje = P × I; 1–5 Bajo, 6–10 Moderado, 11–15 Alto, 16–25 Crítico. El equipo debe documentar la justificación y evaluar efectividad del control antes de estimar el riesgo residual.

08 / PLAN DE ACCIÓN: CONTENER, RECUPERAR Y PREVENIR

Horizonte propuesto	Resultado exigido	Puntos de investigación
0–24 horas	Contención, escalamiento y preservación de evidencia.	Aislamiento selectivo, revocación de sesiones, custodia de registros, continuidad de servicios esenciales.
24–72 horas	Recuperación técnica validada y conciliación.	Análisis de integridad, respaldo limpio, criterios de restablecimiento, seguimiento de alertas.
7–30 días	Corrección de causas raíz.	MFA y privilegios, seguridad de aplicaciones, contratos, cifrado, gestión de cambios.
30–90 días	Prevención y gobierno sostenibles.	BIA, simulacros, indicadores, monitoreo TPRM, auditorías de verificación, riesgo residual.

Cada acción deberá registrar **hallazgo vinculado, prioridad, responsable, recursos, plazo, indicador, evidencia de cierre, verificador y riesgo residual**. Explicar cómo resolver conflictos entre preservar pruebas y restaurar servicios.

RETO FINANCIERO

El comité dispone de un presupuesto limitado de **Q350,000** para acciones en 90 días (supuesto académico). Distribuirlo entre prioridades, justificar costo-beneficio y dejar explícitas acciones no financiadas o riesgos aceptados.

09 / INVESTIGACIÓN ADICIONAL Y FUENTES

Investigar y aplicar prácticas concretas, no solo mencionar siglas. El equipo deberá consultar documentos oficiales y verificar la versión y alcance de cada fuente.

Marco / fuente	Aplicación mínima
ITAF (ISACA)	Procedimientos, evidencia, independencia, juicio, hallazgos y comunicación.
COBIT 2019	Objetivos de gobierno y gestión de TI, responsabilidades, monitoreo.
ISO/IEC 27001	Sistema de gestión y selección pertinente de controles de seguridad.
NIST CSF 2.0	Funciones Govern, Identify, Protect, Detect, Respond y Recover.
NIST SP 800-61	Respuesta a incidentes y mejora a partir del evento.
OWASP Top 10	Riesgos y pruebas de control de aplicaciones y APIs; citar versión consultada.
NIST AI RMF	Gobierno, medición y control de riesgos de IA.

Marco / fuente	Aplicación mínima
Legislación y acuerdos	Investigar obligaciones aplicables en Guatemala y contratos, sin atribuir infracciones sin prueba.

Diez preguntas para el Comité de Auditoría

01. ¿Qué demuestra que los 1.6 GB transferidos fueron exfiltrados y no tráfico legítimo?

02. ¿Cómo separar correlación temporal de causa del incidente?

03. ¿Qué información falta para atribuir los 216 cambios de órdenes?

04. ¿Qué diferencia hay entre respaldo exitoso y restauración verificable?

05. ¿Puede cumplirse un SLA y, aun así, incumplirse la necesidad real del negocio?

06. ¿Cómo preservar la cronología si existe desincronización de relojes?

07. ¿Qué haría si la recuperación inmediata amenaza la cadena de custodia?

08. ¿Cuándo una salida de IA sirve de evidencia y cuándo no?

09. ¿Cómo probaría efectividad de una corrección más allá de instalarla?

10. ¿Qué riesgo residual necesita aceptar expresamente la gerencia?

10 / ENTREGABLES Y PRESENTACIÓN

N.º	Producto obligatorio	Formato sugerido
01	Informe técnico (12–18 páginas sin anexos), con carta de alcance, análisis, hallazgos y plan.	PDF
02	Matrices de riesgos, controles, pruebas y plan de acción con criterios trazables.	XLSX / PDF
03	Papeles de trabajo, inventario E-01 a E-10, custodia y evidencias sintéticas.	PDF / CSV
04	Esquema de base sintética, datos y mínimo seis consultas SELECT documentadas.	SQL / PDF
05	Resumen ejecutivo para Comité de Auditoría y presentación de defensa.	PDF / PPTX
06	Declaración documentada del uso de IA y bibliografía.	Anexo PDF

Defensa: 12 minutos sugeridos por equipo y preguntas del comité. Cada integrante debe demostrar dominio técnico y criterio profesional. El docente podrá introducir evidencia contradictoria de último momento.

11 / RÚBRICA OFICIAL DE ESTE PROYECTO

Criterio	Puntuación
Planeación: objetivos, alcance y metodología	1.0
Identificación y priorización de riesgos	2.0
Controles ITGC, aplicaciones y bases de datos	2.0
Forense: ataque, evidencias y trazabilidad	2.5
Proveedores, cloud, privacidad y cumplimiento	1.5
Calidad de hallazgos y sustento	1.5
Contención, recuperación y continuidad	1.5
Prevención, seguimiento y evaluación de IA	1.5
Informe ejecutivo, presentación y defensa	1.5
TOTAL	**15.0**

Ética, seguridad e integridad académica

- Usar solo datos ficticios y ambientes expresamente autorizados; nunca recolectar DPI, contraseñas ni datos reales.
- No explotar sistemas públicos ni realizar acciones intrusivas; las pruebas serán documentales o de laboratorio.
- Diferenciar hechos confirmados, hipótesis, recomendaciones y evidencia no disponible.
- Registrar uso de IA: herramienta, prompt, salida, verificación manual, ajustes y aprendizaje.
- Citar fuentes originales y evitar evidencia, sentencias o normas inventadas.

OBJETIVO FINAL DEL CURSO

Demostrar trazabilidad completa: **RIESGO → CONTROL → PRUEBA → EVIDENCIA → HALLAZGO → ACCIÓN → VERIFICACIÓN → RIESGO RESIDUAL.**